



Slot 1: HTTP und Web Security

Aufgabenblatt für den Workshop der AG Cyberraum

Kurze Begriffshilfe

Begriff	Bedeutung
Pfad	Teil einer Webadresse, der zu einer Ressource oder Funktion führt
HTTP-Anfrage	Nachricht vom Browser oder einem anderen Client an den Server
HTTP-Antwort	Reaktion des Servers mit Statuscode und Inhalt
Authentifizierung	Prüfung, wer eine Person ist
Autorisierung	Prüfung, was diese Person sehen oder tun darf
SQL	Sprache, mit der viele Anwendungen Datenbanken abfragen

Aufgabe 1: Werkzeugübung: Browserabruf mit curl nachvollziehen

1. Öffnet die Netzwerkansicht der Browser-Entwicklertools.
2. Ruft `http://example.com/` auf und wählt die GET-Anfrage für die Startseite aus.
3. Bestimmt in der Netzwerkansicht Methode, Pfad, Statuscode und relevante Antwortdaten.
4. Führt im Terminal einen entsprechenden Abruf aus (unter Windows möglicherweise mit `curl.exe`):

```
curl -v http://example.com/
```

Die mit > beginnenden Zeilen zeigen die Anfrage, die mit < beginnenden Zeilen die Antwortheader. Darunter folgt der Antwortinhalt. Bestimmt auch hier die vier Merkmale und vergleicht anschließend Anfrage und Antwort mit der Browseransicht.

Merkmal	Browser	curl
Methode		
Pfad		
Statuscode		
Relevante Antwortdaten		



Aufgabe 2: Kurzrecherche: GET und POST vergleichen

Für den Abruf der Startseite wird GET verwendet; bei der späteren Login-Aufgabe werdet ihr eine POST-Anfrage untersuchen. Recherchiert die typische Bedeutung beider HTTP-Methoden und haltet fest, warum die jeweilige Methode zu diesen Aktionen passt.

Methode	Was möchte der Client typischerweise erreichen?
GET	
POST	

Juice Shop lokal starten

Für die folgenden Aufgaben benötigt jedes Team eine eigene Juice-Shop-Instanz. Verwendet ausschließlich diese lokale Workshopumgebung.

1. Startet Docker Desktop beziehungsweise den Docker-Dienst und wartet, bis Docker betriebsbereit ist.
2. Öffnet ein Terminal. Führt den folgenden Befehl in **einer Zeile** aus. Er funktioniert so auch in PowerShell und unter Windows mit installiertem Docker Desktop:

```
docker run --rm --name cyberraum-juice-shop -e 'NODE_CONFIG={"hackingInstructor":{"isEnabled":false}}' -p 127.0.0.1:3000:3000 bkimminich/juice-shop:v20.0.0
```

Beim ersten Start lädt Docker das Image herunter. Das kann einige Minuten dauern. Wartet anschließend, bis im Terminal die Meldung `Server listening on port 3000` erscheint.

3. Lasst dieses Terminal geöffnet. Solange der Prozess dort läuft, ist der Juice Shop unter `http://127.0.0.1:3000` erreichbar.
4. Öffnet die Adresse in einem privaten Browserfenster. Wenn die Startseite erscheint, ist eure Instanz bereit. Verwendet für alle folgenden Aufgaben dieselbe Basis-URL:

```
http://127.0.0.1:3000
```

Falls die Seite nicht erreichbar ist: Prüft zuerst, ob Docker läuft, ob die Startmeldung bereits erschienen ist und ob das Terminal mit dem Container weiterhin geöffnet ist. Bittet danach die Lehrenden um Unterstützung.

Für einen frischen Neustart: Beendet den Container im zugehörigen Terminal mit `Ctrl-C`, wartet auf das Ende des Prozesses und führt denselben `docker run`-Befehl erneut aus. Durch `--rm` wird der beendete Container entfernt. Schließt für einen vollständig frischen Durchlauf außerdem das bisherige private Browserfenster und öffnet ein neues.

Aufgabe 3: Confidential Document (im Team)

Findet und öffnet ein vertrauliches Dokument, das über die Webanwendung erreichbar ist, aber nicht in der normalen Navigation auftaucht.

Ihr dürft jederzeit eine gestufte Hilfe anfordern. Die Verwendung von Hilfen gehört zum Workshop.

Benötigte Hilfe: keine / Stufe 1 / Stufe 2 / Stufe 3

Gefundener Pfad: _____



Wie hätte die Ressource geschützt werden sollen?

Aufgabe 4: Login Admin (gemeinsam)

Meldet euch als Administrator an, ohne das tatsächliche Administratorpasswort zu kennen.

Diese Aufgabe bearbeitet ihr gemeinsam mit den Lehrenden. Achtet dabei auf:

- Methode, Pfad und Eingaben der Login-Anfrage,
- die gezielte Veränderung der Anfrage,
- Statuscode, Token und angemeldetes Konto als Rückmeldung.

Den bekannten Ablauf übertragt ihr in Slot 2 auf ReAct.